

Unit 4 - Web Security

Cryptography and Web Security (DI03016021) - GTU Diploma IT Sem 3

24% weightage | 10 hours

How to use these notes: each topic is written the way you can copy it in the exam. For a **3-mark** question write only the definition + 2-3 points. For **4 marks** add an example or table. For **7 marks** write everything, with diagram and table. Lines marked ★ show where the topic was already asked in a GTU paper (only 2 papers exist so far: Winter 2025 and Summer 2026).

Questions already asked from this unit (do these first)

- Asked in BOTH papers: W2025 Q4(a) [3M: threats on integrity and confidentiality] + S2026 Q4(a) [3M: list and explain three threats]
- Asked in BOTH papers: W2025 Q4(a)OR [3M: network, transport, application level approaches] + S2026 Q5(a) [3M: list three approaches]
- Asked in BOTH papers: W2025 Q4(b) [4M: draw and discuss SSL protocol stack] + S2026 Q4(b) [4M: SSL protocol stack with diagram]
- Asked in S2026 Q4(a)OR [3M: functions of TLS record and TLS alert protocols]
- Asked in S2026 Q4(b)OR [4M: differentiate SSL vs TLS]
- HTTPS asked in BOTH papers: W2025 Q4(b)OR [4M: full forms + connection initiation] + S2026 Q4(c) [7M: initiation and closure]
- SET asked in BOTH papers (7M each): W2025 Q4(c) [role of participants + sequence of events] + S2026 Q4(c)OR [short note on SET]
- Asked in BOTH papers: W2025 Q4(c)OR [7M: compare SSL with SET] + S2026 Q5(a)OR [3M: differentiate SSL and SET]

4.1.1 Web Security Threats

★ Asked in BOTH papers: W2025 Q4(a) [3M: threats on integrity and confidentiality] + S2026 Q4(a) [3M: list and explain three threats]

The web is a two-way network, so servers and browsers both face attacks. Threats are grouped by what they damage:

Threat type	Examples of threats	Consequence	Countermeasure
Integrity	Modification of user data; Trojan-horse browser; modification of memory; modification of messages in transit	Loss of data, machine compromise, vulnerability to other threats	Cryptographic checksums (hash, MAC)
Confidentiality	Eavesdropping on the network; theft of info from server or client; info about network configuration; traffic analysis	Loss of information, loss of privacy	Encryption, web proxies
Denial of Service	Killing user threads; flooding with bogus requests; filling disk/memory; isolating machine by DNS attacks	Disruption, prevents users from getting work done	Difficult to prevent fully
Authentication	Impersonation of legitimate users; data forgery	Misrepresentation of user, belief that false info is valid	Cryptographic techniques (certificates)

Exam tip: 3 marks 'three threats': write Integrity, Confidentiality and Denial of Service with one example line each. For the W2025 wording (integrity + confidentiality) use the first two rows in more detail.

4.1.2 Web Traffic Security Approaches

★ Asked in BOTH papers: W2025 Q4(a) OR [3M: network, transport, application level approaches] + S2026 Q5(a) [3M: list three approaches]

Web traffic security can be added at **three levels** of the protocol stack:

Level	Protocol	How it works	Pros / cons
Network level	IPsec	Security added at the IP layer; encrypts/authenticates all IP packets	Transparent to all applications; but needs OS/router support
Transport level	SSL / TLS	Sits between TCP and the application; secures any TCP-based application (HTTP, FTP, SMTP)	Most common for web (HTTPS); built into browsers
Application level	SET, S/MIME, PGP, Kerberos	Security built into the particular application	Can be tailored to the application's needs, but each application needs its own

Exam tip: 3 marks: name the three levels with the protocol for each (IPsec, SSL/TLS, SET/S/MIME/PGP) and one line each.

4.2.1 SSL Protocol Stack

★ Asked in BOTH papers: W2025 Q4(b) [4M: draw and discuss SSL protocol stack] + S2026 Q4(b) [4M: SSL protocol stack with diagram]

Handshake Protocol	Change Cipher Spec	Alert Protocol	HTTP
SSL Record Protocol			
TCP			
IP			

SSL (Secure Socket Layer) was developed by Netscape. It provides **confidentiality** and **message integrity** for TCP-based applications. SSL is a **two-layer** protocol:

- **SSL Record Protocol** (lower layer): provides basic security. Steps: *fragment* → *compress* → *add MAC* → *encrypt* → *add header*. Gives confidentiality (symmetric encryption) and integrity (MAC).
- **Handshake Protocol**: the most complex part. Client and server authenticate each other, negotiate the encryption algorithm, MAC algorithm and cryptographic keys. It runs in 4 phases: (1) hello messages, (2) server certificate and key exchange, (3) client certificate and key exchange, (4) change cipher suite and finish.
- **Change Cipher Spec Protocol**: a single message (value 1) that tells the other side to start using the newly agreed cipher keys.
- **Alert Protocol**: sends alert messages to the peer; each has a level (**warning** or **fatal**) and a code. Fatal alerts end the connection immediately.

Session vs connection: a *connection* is a temporary peer-to-peer link; a *session* is an association created by the Handshake protocol that can cover many connections (avoids repeating the expensive handshake).

4.2.2 TLS - Record and Alert protocols

★ Asked in S2026 Q4(a) OR [3M: functions of TLS record and TLS alert protocols]

- **TLS Record protocol** - gives two services: **confidentiality** (data is encrypted with a shared secret key) and **message integrity** (an HMAC is added to every record). It fragments data, optionally compresses it, adds the MAC, encrypts it and adds a header. Higher-layer protocols (Handshake, Alert, HTTP) all use it.
- **TLS Alert protocol** - carries TLS-related **alert messages** to the other side. Each alert has 2 bytes: **level** (warning = 1, fatal = 2) and **alert code**. A fatal alert (e.g. bad_record_mac, handshake_failure) terminates the connection at once; a warning (e.g. close_notify) lets it go on or closes it politely. Alerts are encrypted and compressed like normal data.

SSL versus TLS

★ Asked in S2026 Q4(b) OR [4M: differentiate SSL vs TLS]

Point	SSL	TLS
Full form / developer	Secure Socket Layer - Netscape	Transport Layer Security - IETF (RFC 2246)
Version	SSL 3.0 (major version 3, minor 0)	TLS 1.0 = SSL 3.1 (and later TLS 1.2, 1.3)
Message authentication	Own MAC algorithm	HMAC (standard, stronger)
Key generation	Ad-hoc method	Uses a pseudo-random function (PRF) based on HMAC
Alert messages	Fewer alert codes	More alert codes (e.g. decryption_failed, record_overflow)
Cipher suites	Supports Fortezza	Fortezza removed
Current status	Deprecated / insecure	In use (TLS 1.2 / 1.3 are standard today)

4.3 HTTPS: Connection initiation and closure

★ **HTTPS** asked in BOTH papers: W2025 Q4(b) OR [4M: full forms + connection initiation] + S2026 Q4(c) [7M: initiation and closure]

Full forms: **TLS** = Transport Layer Security; **HTTPS** = HyperText Transfer Protocol Secure (HTTP over SSL/TLS). HTTPS uses **port 443** and the URL starts with **https://**.

Connection initiation

In HTTPS the HTTP client also acts as the **TLS client**:



1. Client (browser) opens a TCP connection to the server on port 443.
2. TLS handshake begins: client sends **ClientHello** (supported ciphers); server replies with **ServerHello** and its **certificate**.
3. Client verifies the certificate, both sides exchange keys and agree on session keys, then send **Finished**.
4. Only after the TLS connection is established does the client send the **HTTP request**. The request and the reply travel inside TLS records, so URL, headers, cookies, form data and page content are all **encrypted**.

Connection closure

1. Either side can close the HTTPS connection. The HTTP header can say **Connection: close** to show the connection will be closed after the response.
2. Before closing the TCP connection, TLS sends a **close_notify** alert so the other side knows that the closure is genuine.
3. Then the underlying **TCP connection is closed** (TCP FIN).
4. If TCP is closed **without** a close_notify, a **truncation attack** may have happened - the client reports an error that data may have been cut off. The session can be resumed later using the saved session ID.

4.4 Secure Electronic Transactions (SET)

★ SET asked in BOTH papers (7M each): W2025 Q4(c) [role of participants + sequence of events] + S2026 Q4(c) OR [short note on SET]

SET (Secure Electronic Transaction) is an open protocol developed by **Visa and MasterCard (1996)** to protect **credit-card payments over the internet**. It uses digital certificates (X.509) and a **dual signature**.

Services provided

- Confidentiality of payment and order information.
- Integrity of all transmitted data.
- Authentication of cardholder and merchant (using certificates).
- Privacy: merchant sees only the order, bank sees only the payment.

Participants and their role

Participant	Role
Cardholder	Authorised holder of a payment card (customer). Places the order and pays.
Merchant	Seller of goods/services; offers them for sale and accepts card payments (has certificates).
Issuer	Financial institution (bank) that issued the card to the cardholder; guarantees payment if the transaction is valid.
Acquirer	Merchant's bank; processes card authorisations and payments; gets money from the issuer.
Payment gateway	Operated by the acquirer; links SET to the banking network; processes merchant's authorisation and payment messages.
Certification Authority (CA)	Trusted authority that issues X.509v3 certificates to cardholders, merchants and gateways.

Sequence of events in a transaction

1. Customer **opens an account** with a card-issuing bank (e.g. a credit card).

2. Customer **receives a certificate** (digitally signed by the bank).
3. **Merchants have their own certificates** (one for signing and one for key exchange).
4. Customer **places an order**.
5. Merchant sends its certificate so the customer can **verify the merchant is valid**.
6. Customer sends **order and payment information**, with a **dual signature**: order info is readable only by the merchant, payment info only by the bank.
7. Merchant **requests payment authorisation** from the payment gateway.
8. Merchant **confirms the order** to the customer.
9. Merchant **ships the goods** or provides the service.
10. Merchant **requests payment** from the payment gateway.

4.5 SSL versus SET

★ Asked in BOTH papers: W2025 Q4(c)OR [7M: compare SSL with SET] + S2026 Q5(a)OR [3M: differentiate SSL and SET]

Point	SSL	SET
Purpose	General-purpose security for any TCP application	Specially for credit-card payments on the web
Layer	Transport layer (between TCP and application)	Application layer
Authentication	Server is authenticated; client authentication is optional	All parties (cardholder, merchant, gateway) are authenticated with certificates
Card details	Merchant can see the card number	Merchant never sees the card number (dual signature)
Non-repudiation	Not provided	Provided (digital signatures)
Complexity / cost	Simple, built into browsers, easy to use	Complex, needs special software/wallet and certificates for all
Use today	Very widely used (HTTPS)	Rarely used now

Exam tip: For a 3-mark answer write only the first three rows (purpose, layer, authentication). For 7 marks write all rows.

Last-minute revision sheet - Unit 4

- Web threats: integrity, confidentiality, denial of service, authentication.
- Approaches: network level (IPsec), transport level (SSL/TLS), application level (SET, S/MIME, PGP).
- SSL stack: Handshake, Change Cipher Spec, Alert on top of Record protocol, over TCP.
- Record protocol: fragment → compress → MAC → encrypt → header.
- HTTPS = HTTP over SSL/TLS, port 443. Close with close_notify alert, then TCP close.
- SET participants: cardholder, merchant, issuer, acquirer, payment gateway, CA. Dual signature.